

164.504(e)(2)(i)(B).

****2.4 De-Identification.**** Business Associate may de-identify PHI in accordance with 45 C.F.R. § 164.514(a)-(c). De-identified information is not PHI and is not subject to this BAA.

Business Associate may Use de-identified information for any lawful purpose, including network analytics, capacity planning, pricing analysis, quality measurement, and product development. Business Associate may Disclose de-identified information externally only in aggregated form that does not identify Covered Entity, any Individual, any employer, or any referring entity, except with Covered Entity's prior written permission.

> ****Resolved.**** Broad internal use is preserved for MarketScope, employer utilization reporting, and network analytics. External disclosure is limited to aggregate form not naming the center. Naming a center in comparative benchmarking requires written permission. This is the formulation most likely to survive a compliance officer's review without a negotiation.

****2.5 Prohibited Uses.**** Business Associate shall not Use or Disclose PHI other than as permitted by this BAA, the Agreement, or as Required By Law. Business Associate shall not Use or Disclose PHI in a manner that would violate Subpart E of 45 C.F.R. Part 164 if done by Covered Entity.

****2.6 Minimum Necessary.**** Business Associate shall request, Use, and Disclose only the minimum amount of PHI necessary to accomplish the purpose of the request, Use, or Disclosure.

****2.7 No Sale of PHI.**** Business Associate shall not directly or indirectly receive remuneration in exchange for PHI except as permitted by 45 C.F.R. § 164.502(a)(5)(ii).

****2.8 Marketing.**** Business Associate shall not Use or Disclose PHI for marketing or fundraising purposes.

3. SAFEGUARDS

****3.1 General.**** Business Associate shall use appropriate safeguards, and comply with Subpart C of 45 C.F.R. Part 164 with respect to ePHI, to prevent Use or Disclosure of PHI other than as provided by this BAA.

****3.2 Security Rule Compliance.**** Business Associate shall comply directly with the applicable requirements of the Security Rule, including conducting and documenting a risk analysis, implementing administrative, physical, and technical safeguards, and maintaining written policies and procedures.

****3.3 Workforce.**** Business Associate shall train members of its workforce on their obligations under this BAA and the HIPAA Rules, and shall apply appropriate sanctions for violations.

4. REPORTING

****4.1 Unauthorized Use or Disclosure.**** Business Associate shall report to Covered Entity any Use or Disclosure of PHI not permitted by this BAA of which it becomes aware, without unreasonable delay and in no case later than ****ten (10) business days**** after discovery.

****4.2 Breach Notification.**** ****[DECIDE]**** Business Associate shall provide Covered Entity with preliminary notice of any Breach of Unsecured PHI without unreasonable delay and in no case later than ****five (5) business days**** after discovery. Preliminary notice shall include the fact of the Breach and such information as is then known.

Business Associate shall supplement the preliminary notice as the investigation proceeds, and shall provide a complete account – including the Individuals affected, a description of what occurred, the types of PHI involved, and the steps taken to investigate, mitigate, and prevent recurrence – within ****fifteen (15) business days**** after discovery, or as soon thereafter as reasonably practicable.

> ****Decision required – the operational half.**** Two-stage notice is now drafted: five business days preliminary, fifteen for the complete account. This is more provider-friendly than a single ten-day deadline and easier to actually meet, because the short clock attaches to a fact rather than to a finished investigation.

>

> The constraint is not the deadline. ****It is discovery.**** The clock runs from when Business Associate knew or reasonably should have known. Without monitoring and alerting capable of surfacing an incident, a five-day commitment cannot be met regardless of what the document says. Confirm detection capability before agreeing to five.

>

> The proposed Security Rule update contemplates a 72-hour standard for certain incidents. If adopted, this provision would need conforming.

****4.3 Security Incidents.**** Business Associate shall report Security Incidents as required by 45 C.F.R. § 164.314(a)(2)(i)(C). The parties acknowledge that unsuccessful attempts that do not result in unauthorized access – including routine port scans, pings, and blocked login attempts – need not be reported individually, and that periodic aggregate reporting satisfies this Section as to such attempts.

****4.4 Mitigation.**** Business Associate shall mitigate, to the extent practicable, any harmful effect known to it of a Use or Disclosure in violation of this BAA.

5. SUBCONTRACTORS

****5.1**** Business Associate shall ensure that any Subcontractor that creates, receives, maintains, or transmits PHI on its behalf agrees in writing to restrictions and conditions at least as restrictive as those that apply to Business Associate under this BAA, in accordance with 45 C.F.R. §§ 164.502(e)(1)(ii) and 164.308(b)(2).

****5.2**** ****[DECIDE]**** Business Associate shall maintain a current list of Subcontractors with access to PHI and make it available to Covered Entity upon reasonable request.

> ****Decision required.**** This is standard and increasingly requested. Before agreeing, confirm the downstream chain is actually papered: cloud and database hosting, email and messaging, document execution, analytics, monitoring and error logging, any AI or LLM vendor processing PHI, and any teleradiology or transcription vendor. Each requires its own executed BAA. ****This is the item most likely to be incomplete at go-live**** – vendor BAAs are easy to overlook and slow to obtain.

6. INDIVIDUAL RIGHTS

****6.1 Access.**** Business Associate shall make PHI in a Designated Record Set available to Covered Entity, or as directed to an Individual, within ****fifteen (15) business days**** of request, to enable Covered Entity to meet its obligations under 45 C.F.R. § 164.524.

****6.2 Amendment.**** Business Associate shall make PHI in a Designated Record Set available for amendment and incorporate amendments as directed by Covered Entity, within ****fifteen (15) business days**** of request, in accordance with 45 C.F.R. § 164.526.

****6.3 Accounting of Disclosures.**** Business Associate shall maintain and make available the information required to provide an accounting of Disclosures within ****twenty (20) business days**** of request, in accordance with 45 C.F.R. § 164.528.

****6.4 Restrictions.**** Business Associate shall comply with any restriction on Use or Disclosure of PHI that Covered Entity has agreed to under 45 C.F.R. § 164.522, provided Covered Entity notifies Business Associate of the restriction in writing.

****6.5 Requests Received Directly.**** If Business Associate receives a request directly from an Individual under Sections 6.1 through 6.4, it shall forward the request to Covered Entity within ****five (5) business days**** and shall not respond directly unless directed to do so by Covered Entity.

> ****Operational prerequisite – not a drafting issue.**** Sections 6.1 through 6.5 create hard deadlines. Before execution, USRad needs a documented intake path: where requests arrive, who verifies the requester's identity, who owns the response, where deadlines are tracked, and how Covered Entity instructions are recorded. The language is standard; the queue behind it does not exist yet. Missed deadlines here are a compliance failure regardless of good faith.

7. GOVERNMENT ACCESS

Business Associate shall make its internal practices, books, and records relating to the Use and Disclosure of PHI available to the Secretary for purposes of determining compliance with the HIPAA Rules. Business Associate shall notify Covered Entity of such a request unless prohibited by law.

8. OBLIGATIONS OF COVERED ENTITY

****8.1**** Covered Entity shall notify Business Associate of any limitation in its notice of privacy practices, any change in or revocation of an Individual's permission to Use or Disclose PHI, and any restriction agreed to under 45 C.F.R. § 164.522, to the extent any of these affects Business Associate's permitted Uses or Disclosures.

****8.2**** Covered Entity shall not request that Business Associate Use or Disclose PHI in a manner that would not be permissible under the HIPAA Rules if done by Covered Entity, except as permitted under

****BUSINESS ASSOCIATE****

U.S. RADIOLOGY OF FLORIDA, LLC D/B/A USRad

Signature: _____

Name: Michael Cabrera

Title: President & CEO

Date: _____

CONFORMING CHANGES TO THE PSA

Three changes required. None is optional if this exhibit is added.

****1. § 2.5 – Confidentiality and Security.**** Currently requires HIPAA compliance but never requires execution of a BAA. Add:

> The parties shall execute the Business Associate Agreement attached as Exhibit C, which forms an integral part of this Agreement.

****2. § 9.1 – Survivability.**** Add Exhibit C to the list of surviving provisions.

****3. Exhibit lettering.**** Current PSA has Exhibit A (Reimbursement Schedule) and Exhibit B (Provider Locations). This becomes Exhibit C. Update any cross-references.

WHAT THIS COMMITS USRad TO

The document is cheap. Performance is not. Signing this makes USRad directly liable under the Security Rule for:

Obligation	Status
Documented risk analysis	Required before first PHI receipt
Written security policies and procedures	Required
Workforce HIPAA training and sanctions policy	Required
Incident response plan capable of 10-business-day breach notice	Required
Executed BAAs with every downstream vendor touching PHI	**Most likely gap at go-live**
Access controls, audit logging, encryption	Current rule: encryption is "addressable." Proposed rule would mandate it
Designated security official	Required
Individual access / amendment / accounting request queue	Required by §§ 6.1-6.5. Does not exist yet
Monitoring capable of supporting a five-business-day discovery clock	Required by § 4.2

The proposed Security Rule update – mandatory encryption, MFA, 72-hour incident reporting, annual penetration testing, expanded business associate oversight – remains proposed, with final action currently targeted for July 2027 and no certainty it will be adopted as drafted. Building toward it now is materially cheaper than retrofitting a live platform.

EMPLOYER SIDE – SEPARATE AND NOT COVERED HERE

A self-funded group health plan is itself a Covered Entity. Employer arrangements involving eligibility files, claims or utilization data, or member reporting require their own BAA, with the Plan as Covered Entity and USRad as Business Associate.

****This is why § 2.1(b) was narrowed.**** Eligibility verification against a plan is performed on behalf of the plan, not on behalf of the imaging center. Placing it in the provider BAA mischaracterized the relationship. The provider BAA now covers only funding-status confirmation for a routed Assignment; plan-side eligibility belongs in the employer BAA.

****Counsel should validate role assignment per data flow rather than assume one universal relationship.**** Depending on the transaction, USRad may be a business associate of the imaging center, a business associate of a group health plan, a recipient of information directly from an Individual, or a party to a treatment disclosure requiring no BAA at all. The four can occur within a single assignment.

That document belongs in the employer agreement set, which does not yet exist. Recorded here as a gap, not addressed by this exhibit.

**Draft prepared for review by healthcare counsel licensed in the State of Florida. Not for execution.
This is a legally required document carrying direct statutory liability; counsel review is not optional.**